

Prime Classy Cake & Cookies

Blueprint Platform — Teknologi, Alur Kerja, Fitur, Proses Bisnis & Permission

Dihasilkan dari kondisi kode aktual — September 2026

Blueprint — Prime Classy Cake & Cookies

Dokumen ini merangkum kondisi aplikasi **saat ini** (bukan rencana/wacana) — arsitektur, alur kerja, fitur, proses bisnis, level user & permission-nya, serta hal-hal penting lain yang perlu dipahami siapa pun yang akan mengembangkan, mengelola, atau men-deploy platform ini.

1. Ringkasan

Prime Classy Cake & Cookies adalah platform **pemesanan kue & kukis multi-cabang (multi-agen)**. Setiap **agen** (cabang) punya toko, stok, staf, dan operasional pengiriman sendiri-sendiri, sementara satu **super_admin** mengawasi seluruh platform. Konsumen berbelanja dari katalog bersama, terhubung ke satu cabang lewat rantai referral (agen → korsal → sales → konsumen), dan bisa checkout dengan kurir cabang, COD, transfer bank manual, atau payment gateway (Xendit/Tripay/Stripe).

2. Teknologi yang Dipakai

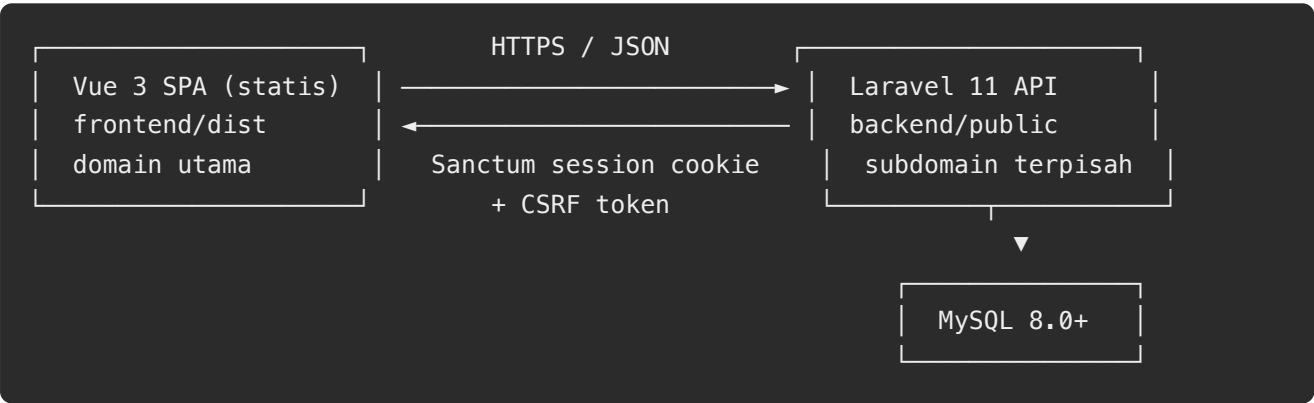
Backend

Komponen	Versi/Detail
Bahasa & Framework	PHP 8.2+, Laravel 11
Database	MySQL 8.0+ (dikembangkan di MySQL 8.4)
Autentikasi	Laravel Sanctum — mode SPA cookie session (bukan bearer token)
Sanitasi konten CMS	HTMLPurifier (ezyang/htmlpurifier)
Export Excel	PhpSpreadsheet (phpoffice/phpspreadsheet)
Testing	PHPUnit — 349 automated Feature test , jalan terhadap database test sungguhan

Frontend

Komponen	Versi/Detail
Framework	Vue 3 (Composition API) + Vite
Routing & State	Vue Router, Pinia
Styling	Tailwind CSS v4
Editor	CKEditor 5 (rich-text untuk konten CMS)
HTTP Client	Axios
i18n	vue-i18n — 4 bahasa (Indonesia, Inggris, Arab, Mandarin)

Arsitektur Deployment



Frontend dan backend adalah dua aplikasi yang di-deploy TERPISAH — frontend murni file statis (`frontend/dist/`) yang berkomunikasi ke backend lewat HTTP JSON saja; backend tidak pernah merender halaman HTML apa pun selain `public/index.php` sebagai front controller. Karena otentikasi berbasis cookie sesi (bukan token bearer), kedua domain **wajib berbagi domain terdaftar yang sama** (mis. `toko.domainanda.com` + `api.domainanda.com` , sama-sama di bawah `domainanda.com`) — lihat §8 untuk detail konfigurasi cross-domain-nya.

Konfigurasi Runtime Frontend (tanpa rebuild)

URL backend API di frontend **tidak di-hardcode saat build**, melainkan dibaca dari `frontend/dist/config.js` (dimuat sebagai `<script>` sebelum bundle utama). Ini artinya satu hasil build bisa dipakai untuk domain apa pun — tinggal edit satu baris di `config.js` lewat File Manager hosting, tanpa perlu `npm run build` ulang. Cocok untuk shared hosting tanpa akses terminal.

3. Alur Kerja (Workflow) Sistem

3.1. Instalasi Awal (Installer Wizard)

Aplikasi punya wizard instalasi berbasis browser (`/install` di frontend, `POST/GET /api/v1/install/*` di backend) yang membuat deploy ke shared hosting **tanpa terminal** jadi mungkin:

1. **Selamat Datang** → **Persyaratan Server** (cek versi PHP, ekstensi, permission folder).
2. **Database** — input host/nama DB/user/password MySQL, test koneksi, simpan otomatis ke `.env`.
3. **Konfigurasi Aplikasi** — nama aplikasi, URL backend, URL frontend (menulis `FRONTEND_URLS` / `SANCTUM_STATEFUL_DOMAINS` / `SESSION_DOMAIN` ke `.env` otomatis).
4. **Akun Super Admin** — input data admin pertama.
5. **Instalasi Database** — menjalankan migrasi + seeder + membuat akun Super Admin, sekaligus `storage:link`, semua lewat satu klik dari browser (bukan CLI).
6. **Finalisasi** — verifikasi ringkasan instalasi.
7. **Kunci Instalasi** — mengunci wizard secara **permanen**; setelah ini seluruh endpoint `/install/*` selalu menolak (403), bahkan kalau file lock-nya hilang (double-guard: cek lock file DAN cek apakah Super Admin sudah ada).

`APP_KEY` dibuat otomatis oleh aplikasi sendiri pada request pertama (tidak perlu `php artisan key:generate`). Selama proses instalasi berlangsung (belum terkunci), CORS dan domain sesi Sanctum otomatis "memantulkan" origin yang benar-benar meminta — begitu instalasi dikunci, keduanya kembali ketat sesuai `FRONTEND_URLS` / `SANCTUM_STATEFUL_DOMAINS` yang dikonfigurasi.

3.2. Alur Registrasi & Hierarki Referral

```
super_admin
├── agen (per cabang/toko)
│   ├── korsal (koordinador sales)
│   │   └── sales
│   │       └── konsumen (lewat kode referral sales)
│   ├── sales (langsung di bawah agen)
│   │   └── konsumen (lewat kode referral sales)
│   ├── admin (staf kantor cabang)
│   └── kurir (staf pengiriman cabang)
```

konsumen juga bisa daftar langsung pakai kode referral agen ATAU korsal (tanpa sales perantara) — `sales_id/korsal_id` yang dilewati jadi null.

- Setiap **agen**, **korsal**, **sales** otomatis punya `referral_code` unik saat dibuat (format `{PREFIX}-{6 karakter acak}`), dan bisa mengelola sendiri kodenya (lihat/ubah manual/acak ulang/hapus) lewat halaman Profil.
- **konsumen**, **admin**, **kurir** tidak pernah punya referral code.
- Siapa boleh membuat siapa: `super_admin` → agen/korsal/sales/admin/kurir; `agen` → korsal/sales/admin/kurir; `korsal` → sales saja. Konsumen mendaftar sendiri (self-registration) via

kode referral.

- Rantai referral (`sales_id` / `korsal_id` / `agent_id`) di-snapshot pada saat pendaftaran konsumen dan **tidak berubah otomatis** — memindahkan sales ke korsal lain, atau konsumen ke sales lain, adalah aksi eksplisit & tercatat di audit log (`ReferralReassignmentService`), tidak pernah terjadi diam-diam.
- Isolasi data per-cabang diterapkan berlapis: query level (`BelongsToAgentScope`), policy level, dan service level — satu agen tidak pernah bisa melihat data agen lain.

3.3. Alur Belanja & Checkout (Konsumen)

1. Jelajahi katalog (produk bisa punya varian, harga & stok per-agen).
2. Tambah ke keranjang / wishlist.
3. Checkout: pilih alamat (tersimpan atau input manual + opsi simpan alamat baru), pilih tanggal kirim, pilih metode pengiriman (**Kurir Online** — dihitung jarak jalan sungguhan via OpenRoute API dengan fallback jarak lurus Haversine — atau **Ekspedisi** via RajaOngkir), pilih metode pembayaran.
4. Metode pembayaran yang tersedia: **COD**, **Transfer Bank Manual** (upload bukti transfer, diverifikasi admin), atau **Payment Gateway** (Xendit/Tripay/Stripe, webhook dengan verifikasi signature).
5. Order dibuat — **setiap item produk mendapat Shipment-nya sendiri secara independen** (bukan satu shipment untuk seluruh order), supaya satu order bisa ditangani oleh beberapa kurir berbeda sekaligus, dan reschedule satu produk tidak mengganggu produk lain dalam order yang sama.
6. Status order: **COD langsung masuk status diproses** (tidak perlu verifikasi pembayaran dulu, karena memang belum ada yang dibayar) — sedangkan transfer manual/gateway tetap mulai di **diterima** sampai pembayarannya diverifikasi.

3.4. Alur Fulfillment & Pengiriman (Kantor & Kurir)

```
diterima → diproses → dikirim → terkirim → (pengembalian → kembali, jika ada retur)
      |
      |_____→ dibatalkan (sebelum dikirim)
```

- **Kantor** (agen/admin/super_admin) memproses order (`diterima` → `diproses`), bisa menyesuaikan jumlah item yang dipenuhi (kurang stok → refund/pembatalan parsial; tambah → additional payment, kecuali COD), dan bisa **mengubah tanggal kirim per produk** — termasuk memindah **sebagian jumlah** dari satu produk ke tanggal lain (memecahnya jadi baris/shipment baru, order & pembayaran tetap satu).
- **Kurir** melihat semua order berstatus `diproses` di cabangnya (belum diklaim siapa pun), mengambilnya (self-assign saat menekan "Ambil" → status `dikirim`), lalu menandai `terkirim` **wajib disertai foto bukti pengiriman**. Sekali sebuah shipment diambil kurir tertentu, kurir lain tidak bisa melihat/memrosesnya lagi (baik di dashboard kurir maupun halaman detail order) — walau order yang sama masih berisi produk lain yang belum diambil siapa pun.
- **Retur**: konsumen mengajukan retur (wajib foto bukti) untuk item yang sudah `terkirim` → kurir menjemput retur (`pengembalian`) dengan catatan kondisi barang → admin meninjau (approve/reject) → jika approve, stok dikembalikan & status refund dikelola terpisah.
- Aturan pembatalan: **COD** boleh dibatalkan selama masih `diterima` ATAU `diproses` ; **non-COD** hanya boleh dibatalkan selama `diterima` (begitu `diproses` , uang sudah/akan diverifikasi

terkumpul — pembatalan lewat jalur retur/refund, bukan cancel biasa).

3.5. Alur Fee & Komisi

- Setiap produk/varian punya 3 jenis fee yang bisa dikonfigurasi: **fee agen**, **fee sales**, **fee kurir** — nilainya di-snapshot ke `order_items` saat order dibuat (perubahan fee di kemudian hari tidak mengubah order lama).
- Komisi kurir baru dicatat saat item benar-benar `terkirim` (bukan saat order dibuat).
- Visibilitas fee dibatasi ketat per role (lihat §5) — kurir dan konsumen tidak pernah melihat angka fee/harga modal apa pun.

4. Fitur yang Ada

- **Autentikasi & Otorisasi**: Sanctum SPA cookie session, 7 role, hierarki & permission per role, audit trail lengkap (`ActivityLogger` → tabel `activity_logs` , mencatat siapa-apa-kapan-dari IP/user agent mana).
- **Manajemen Pengguna**: CRUD user sesuai hierarki, reassign referral (pindah sales↔korsal, konsumen↔sales), status akun (active/inactive/suspended dengan badge berbeda).
- **Katalog Produk**: produk dengan/tanpa varian, kategori, gambar (multi-gambar per produk, satu primary), stok per-agen, per-varian; harga mulai ("starting price") otomatis dari varian termurah kalau produk punya varian.
- **Keranjang, Wishlist, Checkout**: dengan quote real-time (subtotal, ongkir, biaya admin) sebelum submit order, idempotency key untuk mencegah order duplikat dari klik ganda/retry jaringan.
- **Order Lifecycle Lengkap**: lihat §3.4 — termasuk penyesuaian fulfillment per item, reschedule tanggal kirim (termasuk split kuantitas), pembatalan, retur/refund per-item, additional payment.
- **Alamat Tersimpan (Konsumen)**: buku alamat dengan cascading Provinsi/Kota/Kecamatan/Kelurahan, bisa dipakai langsung saat checkout.
- **Pembayaran**: COD (dengan foto bukti + konfirmasi admin), Transfer Bank Manual (foto bukti + verifikasi admin), 3 payment gateway (Xendit/Tripay/Stripe) dengan webhook terverifikasi signature dan idempotency guard (event yang sama tidak diproses dua kali).
- **Pengiriman**: Kurir Online (OpenRoute, fallback Haversine) dan Ekspedisi (RajaOngkir tier starter/basic/pro), keduanya admin-configurable per cabang, keduanya fail-safe (tidak pernah memblokir checkout kalau provider down).
- **Dashboard Kurir**: daftar order siap ambil, tab retur, tab riwayat selesai (dengan rekap fee milik kurir itu sendiri saja, tidak pernah fee kurir lain).
- **CMS**: blok konten homepage, artikel/berita, halaman statis — semua lewat CKEditor 5, disanitasi server-side sebelum disimpan (mencegah XSS).
- **Website Settings**: nama situs, logo, favicon, slogan, kontak, sosial media — publik & bisa diedit Super Admin; header frontend/dashboard otomatis pakai logo yang di-upload (fallback ke teks kalau belum ada logo).
- **Direktori "Cari Agen/Toko"**: publik, dengan kode referral yang bisa langsung disalin (klik untuk copy).

- **Media Upload:** pipeline dengan validasi MIME/tipe file sungguhan (bukan cuma cek ekstensi), nama file di-generate (tidak pernah dari nama asli), batas ukuran per jenis (umumnya maks 4MB gambar).
- **Multi-bahasa:** 4 bahasa penuh di backend (pesan error/sukses) dan frontend (UI) — Indonesia, Inggris, Arab (RTL), Mandarin.
- **Laporan:** 5 laporan manajemen dengan export Excel (.xlsx) — transaksi, fee sales/korsal, pembatalan & refund, fee kurir, fee agen — semua bisa difilter per cabang (Super Admin lintas cabang, agen cabang sendiri).
- **Payment Gateway & Shipping Provider Admin:** kredensial disimpan terenkripsi di database (bukan `.env`), tidak pernah ditampilkan kembali lewat API setelah disimpan.

5. Level User & Permission

7 role tetap (`roles` table), tanpa role kustom:

Role	Posisi	Bisa Bikin Akun	Referral Code	Lihat Data
super_admin	Puncak, lintas cabang	agen, korsal, sales, admin, kurir	✗	Semua cabang
agen	Pemilik/kepala cabang	korsal, sales, admin, kurir	✓	Cabangnya sendiri (network)
korsal	Koordinator sales	sales	✓	Sales & konsumen di bawahnya
sales	Penjual, punya kode referral konsumen	—	✓	Konsumen miliknya sendiri
konsumen	Pembeli	—	✗	Order miliknya sendiri
admin	Staf kantor cabang (dibuat agen)	—	✗	Cabang yang menugaskannya
kurir	Staf pengiriman cabang	—	✗	Order/shipment yang diklaimnya

Capability map (`PermissionMap`) — hint untuk UI, selalu di-cross-check ulang di server:

Permission	super_admin	agen	admin	korsal	sales	konsumen	kurir
<code>system.config.manage / system.payment.manage / system.shipping.manage / system.cms.manage</code>	✓						
<code>users.view.all</code>	✓						
<code>users.view.network</code>		✓	✓	✓	✓		
<code>stock.view.own / stock.manage</code>		✓	✓				
<code>orders.view.all</code>	✓						
<code>orders.view.network</code>		✓	✓	✓	✓		
<code>orders.view.own</code>						✓	
<code>orders.view.assigned</code>							✓
<code>orders.create</code>		✓		✓	✓	✓	
<code>orders.manage.status / .fulfillment / .shipment</code>	✓	✓	✓				(shipment saja)
<code>orders.manage.payment</code>	✓	✓	✓				
<code>orders.cancel</code>	✓	✓	✓				

Aturan visibilitas fee (contoh kontrol paling ketat di sistem):

- **agent_fee**: hanya super_admin & agen.
- **sales_fee**: super_admin, agen, sales (miliknya sendiri), admin.
- **courier_fee**: super_admin, agen, admin — **tidak pernah sales, tidak pernah konsumen, tidak pernah kurir sendiri** (kurir tahu dia dibayar, tapi tidak melihat angka fee mentah lewat API order).
- Konsumen dan kurir **tidak pernah** melihat field harga/fee/subtotal/payment_status pada endpoint yang memang didesain untuk mereka (`CourierOrderResource` khusus kurir sengaja tidak menyertakan field uang sama sekali).
- Konsumen **tidak** melihat identitas sales/korsal yang menangani ordernya sendiri (informasi rantai referral internal, bukan urusan konsumen).

6. Proses Bisnis Kunci (Aturan yang Sering Jadi Sumber Bug Kalau Dilanggar)

1. **Harga/fee/stok/total tidak pernah dipercaya dari klien** — semua dihitung ulang di server dari database di setiap request, klien cuma kirim ID produk + kuantitas.
 2. **Snapshot, bukan referensi hidup** — harga, fee, alamat pengiriman, dll di order/item disalin ("snapshot") saat transaksi terjadi. Perubahan harga produk/fee di kemudian hari tidak pernah mengubah order yang sudah ada.
 3. **COD = belum ada uang masuk** — tidak pernah masuk ke sistem refund (karena tidak ada yang harus dikembalikan), pengurangan kuantitas pada COD adalah pembatalan biasa, bukan refund; penambahan kuantitas pada COD tidak membuat "additional payment" terpisah (nempel ke total COD yang akan dibayar sekaligus saat barang sampai).
 4. **Satu order, banyak shipment, banyak kurir** — konsekuensi dari aturan "reschedule per produk" dan "kurir tidak boleh saling mengambil order kurir lain". Status order keseluruhan adalah hasil rangkuman dari status semua shipment-nya.
 5. **Idempotency** — pembuatan order pakai `Idempotency-Key` header; retry jaringan/klik ganda tidak pernah membuat order duplikat. Webhook payment juga idempotent per event.
 6. **Audit trail wajib** — setiap aksi yang mengubah data penting (status order, pembatalan, perubahan fee, perubahan setting, dll) tercatat di `activity_logs` dengan actor, role actor, data sebelum/sesudah, dan alasan (kalau relevan) — tidak pernah cuma "status berubah" tanpa jejak.
 7. **Isolasi cabang berlapis** — bukan cuma difilter di query, tapi juga dicek ulang di policy/service layer sebagai lapisan kedua (defense in depth) — satu baris kode yang lupa filter tidak langsung jadi kebocoran data lintas cabang.
 8. **Fail-safe pada layanan eksternal** — OpenRoute/RajaOngkir/payment gateway yang gagal/down tidak pernah memblokir alur inti (checkout tetap jalan dengan fallback ongkir; error gateway ditangani per-gateway).
-

7. Keamanan

- Setiap upload file diverifikasi MIME/tipe sungguhan (bukan sekadar ekstensi), disimpan dengan nama ter-generate.
- Kredensial payment gateway & shipping provider **tidak pernah** di `.env` — hidup di database terenkripsi, hanya lewat layar admin, tidak pernah dikembalikan lewat API setelah disimpan.
- Rate limiting diterapkan di login, registrasi, checkout, dan webhook pembayaran.
- CSRF (Sanctum) aktif di semua endpoint yang butuh sesi login, **kecuali** endpoint wizard instalasi (`/install/*`) — sengaja dikecualikan karena endpoint ini hanya bisa dipakai sebelum aplikasi ter-install sama sekali (tidak ada data sungguhan untuk diserang), dan otomatis tersegel permanen begitu instalasi dikunci.
- Cookie sesi memakai `SameSite=None; Secure=true` secara default (bukan `Lax`) — konsekuensi langsung dari arsitektur frontend/backend yang selalu beda domain; production **wajib** HTTPS di kedua domain.

- Frontend dan backend beda domain juga berarti `SESSION_DOMAIN` di `.env` backend perlu diisi domain induk bersama (mis. `domainanda.com`) kalau frontend & API adalah subdomain dari domain yang sama — tanpa ini, cookie CSRF tidak bisa dibaca lintas subdomain oleh JavaScript frontend meski request-nya sendiri tetap terkirim (gejalanya: "CSRF token mismatch" terus-menerus).
 - `APP_DEBUG=false` di production menyembunyikan detail teknis error dari respons API — cek `backend/storage/logs/laravel.log` untuk detailnya.
-

8. Hal Penting Lain untuk Yang Meneruskan/Mengelola Proyek Ini

- **Migrasi adalah sumber kebenaran skema**, bukan `database.sql` (itu cuma dump hasil ekspor, jangan diedit langsung dan berharap berpengaruh ke aplikasi).
- **Tidak ada demo data/user bawaan** — seeder hanya mengisi role tetap, 4 bahasa, payment method dasar (cod/bank_transfer aktif; xendit/tripay/stripe nonaktif sampai dikonfigurasi), dan pengaturan default. Super Admin pertama dibuat lewat wizard instalasi (§3.1).
- **Backup**: database (mysqldump/snapshot host) + `backend/storage/app/public` (semua file upload — tidak bisa direproduksi dari database saja) + `.env` (simpan aman terpisah, jangan sertakan di backup publik).
- **File upload tersimpan di `storage/app/public`**, diakses lewat symlink `public/storage` — kalau gambar 404 padahal sukses upload, biasanya symlink ini belum dibuat (wizard instalasi sudah otomatis mencoba membuatnya).
- **Belum ada test otomatis untuk frontend** — verifikasi perubahan frontend masih manual (jalankan dev server, cek di browser). Backend punya 349 test otomatis (`php artisan test`).
- **Belum ada command backup bawaan** — backup terjadwal harus disiapkan sendiri di level infrastruktur (cron + mysqldump, atau fitur snapshot dari penyedia hosting/database).
- Dokumen referensi tambahan yang lebih teknis/mendalam: `README.md` (instalasi & konfigurasi detail — perlu diperbarui mengikuti wizard instalasi baru), `backend/SECURITY_AUDIT.md`, `backend/FINAL_AUDIT_REPORT.md`.